Práctica CISO

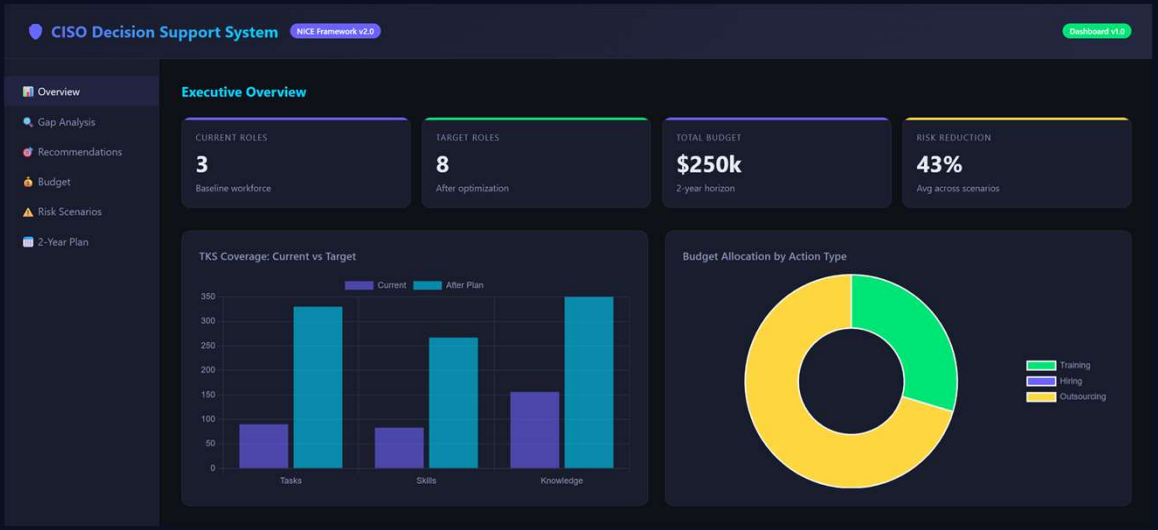
Decision Support System (DSS) NICE Framework Alignment

Presentación ejecutiva del toolkit NICE aplicado al diseño del plan de ciberseguridad

24 meses | $250k presupuesto máximo | 4 escenarios de riesgo | NICE v2.1.0

Qué vamos a contar

1. Cómo cambia el equipo y por qué
2. Cómo se reparte el presupuesto en 24 meses
3. Qué reducción heurística del riesgo conseguimos



Toolkit para maximizar cobertura NICE (TSK) bajo restricción de presupuesto

1. Del equipo actual al plan recomendado bajo presupuesto

Partimos de un equipo reactive de 3 roles y priorizamos capacidades que nos acerquen a una postura proactive y security by design

ESTADO ACTUAL

PD-WRL-001

Defensive Cybersecurity

Defensa operativa y mitigación de riesgos

PD-WRL-003

Incident Response

Investigación y respuesta ante incidentes

IO-WRL-005

Systems Administration

Administración y mantenimiento del sistema

DESPLAZAMIENTO ESTRATÉGICO

FOCO OBJETIVO

OG-WRL-008

Privacy Compliance

Cumplimiento normativo y protección de datos

OG-WRL-012

Security Control Assessment

Evaluación de controles de seguridad y su efectividad

PD-WRL-002

Digital Forensics

Análisis forense de evidencias digitales

PD-WRL-005

Insider Threat Analysis

Detección y análisis de amenazas internas

DD-WRL-001

Cybersecurity Architecture

Diseño seguro y controles by-design

2. Roadmap de 24 meses

Plan secuencial: activar capacidad rápida, cubrir especialización externa y consolidar diseño seguro

1 Fase 1 · Meses 1-6

Training

- Upskill Systems Administration → $9,500
- Upskill Defensive Cybersecurity → $52,000
- Upskill Privacy Compliance → $12,500

2 Fase 2 · Meses 1-24

Outsourcing

- Digital Forensics → $76,000
- Cybersecurity Architecture → $100,000

3. Utilización del presupuesto

2-Year Implementation Roadmap

Phase 1 — Months 1-6: Training & Upskilling

- **Security Control Assessment (OG-WRL-012)** ← upskill Systems Administration
  Cost: $9500 · +52 tasks · +123 skills
- **Insider Threat Analysis (PD-WRL-005)** ← upskill Defensive Cybersecurity
  Cost: $52.000 · +56 tasks · +28 skills
- **Privacy Compliance (OG-WRL-008)** ← upskill Incident Response
  Cost: $12.500 · +72 tasks · +12 skills

Phase 3 — Months 1-24: Outsourcing

- **Digital Forensics (PD-WRL-002)**
  Cost: $76.000 · +38 tasks · +35 skills
- **Cybersecurity Architecture (DD-WRL-001)**
  Cost: $100.000 · +41 tasks · +25 skills

Budget Summary

STRATEGY	COUNT	2-YEAR COST
Training & Upskilling	3	$74.000
Outsourcing	2	$176.000
Total	**5**	**$250.000**
Remaining		$0

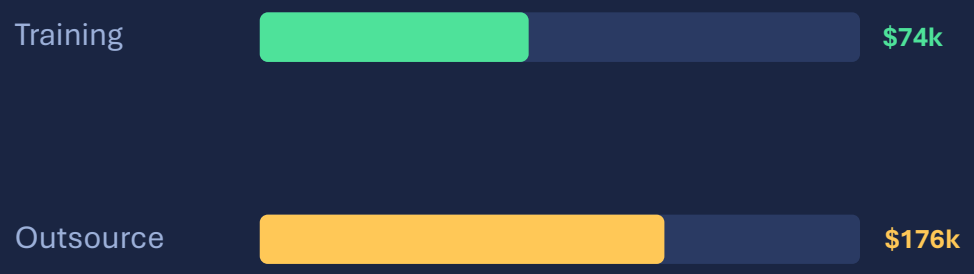
4. Cómo se utiliza el presupuesto en los 2 años

La mayor inversión va delante para activar capabilities rápidamente; el segundo año financia continuidad y madurez

Distribución por año

Año 1: training + primer año de outsourcing - 65%
Año 2: continuidad del outsourcing – 35%

Asignación por capability



Interpretación ejecutiva

- La inversión se adelanta al inicio del plan: en los primeros 6 meses se cierran rápido las brechas de capacidad más críticas
- El training crea autonomía operativa
- El outsourcing asegura cobertura experta durante los 24 meses

5. Cómo medimos la heuristic risk reduction

No es una auditoría formal: es un proxy ejecutivo alineado con la lógica del comando risk del toolkit

1 Escenarios

1. Ransomware
2. Data leak / insider
3. Audit / compliance
4. Supply chain compromise

Base de datos usada:
risk_scenarios.json

2 Relevancia de roles

Asignamos pesos heurísticos según la descripción NICE de cada rol:

- Threat Analysis
- Vulnerability Analysis
- Cybersecurity Architecture
- Defensive Cybersecurity
- Incident Response

Fuente de fuerza relativa:
risk_impact_pct del CSV de costes

3 Índice resultante

Fórmula heurística:

Score = sum(wT · Tasks + wS · Skills + wK · Knowledge)

Este índice sirve para explicar tendencia y priorización, no para certificar cumplimiento

6. Resultado: aumenta la cobertura de mitigación en los 4 escenarios

La métrica representa el % de tareas NICE requeridas cubiertas antes y después del plan

7. Conclusiones

No temenos solo una recomendación de roles, sino un plan ejecutable con coste y efecto de riesgo explicables

Storyline

1. Partíamos de un equipo pequeño y muy táctico

2. NICE nos permite expresar el gap en TKS y traducirlo después a decisions de equipo

3. Con las restricciones de presupuesto, el mejor plan no es contratar todo, sino combiner upskilling y outsourcing selectivo

4. Esa mezcla reduce el riesgo residual de forma visible en escenarios relevantes

Tres números para recordar

24
meses
roadmap realista

250k
presupuesto
100% del presupuesto

43%
pts riesgo
mitigación media residual

Gracias